STEM Website Roadmap Progress Report

Senior developer review and implementation record - updated 20 October 2026

Executive summary

The repository is now materially safer for continued development. The backend progression path uses server-authoritative validators, idempotent attempt receipts, and final revocation of direct legacy RPC access. Both existing games now route platform operations through their adapters. CI has dependency and syntax checks, and local verification passes 32 of 32 tests.

Important boundary

The two future game modules were not implemented. The work stops at preparation and stabilization, as requested. Hosted Supabase actions were not automated from this workspace; the final privilege screenshot supplied by the user confirms the cleanup migration result.

Roadmap status

Roadmap item	Status	Evidence / result
1. Protect current state	Complete	Dedicated branch feature/platform-stabilization; existing work preserved; changes committed in sequence.
2. Reproducible repository	Mostly complete	README, Supabase config, CI workflow, pinned browser CDN. A committed package-lock remains desirable but could not be generated in the local runtime.
3. Backend authority	Complete for current scope	Migrations 011-013 revoke legacy client-trusted access, add authoritative wrappers, add receipt idempotency, and revoke direct authoritative RPCs after deployment.
4. Game boundaries	Improved / partial	PhysicsSim and RoboMaze adapters now own progress, mistake, tutor, and achievement calls. Large HTML entry files still contain UI orchestration.
5. Server validation	Implemented	RoboMaze and Physics authoritative submit procedures validate attempts and calculate server results.
6. Tutor reliability	Implemented with external limitation	Retries, timeout, provider states, quota refund, safe fallback, and privacy-safe request/result logs. Gemini rate limits remain an external service constraint.
7. Tests and quality	Substantially complete	32 local Node tests pass; repository and web-quality checks pass; CI Deno configuration fixed. Browser E2E, accessibility automation, and hosted DB tests remain.
8. Module contract	Partial	StemGameModule contract exists and both games expose modules; full lifecycle migration remains.
9. Future games	Deferred	No new game was added before the existing platform is fully stabilized.

Implemented changes

Backend protection

The idempotent submit wrappers use a per-user, per-game, per-attempt receipt key. Duplicate submissions return the saved result instead of awarding progress twice. Migration 013 removes client access to the old direct submit procedures after the compatibility window.

Game adapter boundary

RoboMaze/adapter.js and PhysicsSim/adapter.js now provide submitAttempt, recordMistake, analyzeMistake, and recordAchievement. Game HTML no longer calls these platform APIs directly.

Tutor observability

The browser records only tutor state and latency. The Edge Function records request ID, game ID, level number, provider status when relevant, result state, and latency. It intentionally excludes prompts, responses, student IDs, and attempt details.

Quality gates

scripts/verify-web-quality.mjs checks required metadata, local script and stylesheet references, the pinned Supabase browser dependency, and adapter-boundary compliance. CI also syntax-checks JavaScript in js, PhysicsSim, and RoboMaze.

Verification evidence

The following checks were run locally after the final changes:

- node scripts/verify-repo.mjs - passed

- node scripts/verify-web-quality.mjs - passed

- Node syntax checks for all JavaScript in js, PhysicsSim, and RoboMaze - passed

- 32 automated tests - 32 passed, 0 failed

- git diff --check - no whitespace errors

- User-confirmed Supabase privilege state: legacy direct submit procedures false; idempotent wrappers true

Remaining work and manual gates

- Generate and commit package-lock.json from a normal Node/npm environment, then consider changing CI from npm install to npm ci.

- Push the current local changes and wait for GitHub Actions. The local runtime cannot reproduce the hosted Deno test without its dependency download environment.

- Run the supplied SQL verification queries in Supabase after deployment and retain the result as release evidence.

- Perform browser tests for login, expired sessions, failed writes, duplicate attempts, tutor 429 fallback, and level unlocks.

- Add a real browser accessibility/link test layer before introducing new games.

- Complete the full module lifecycle migration, then define and implement each new game with canonical data, server validation, independent progression, tests, and tutor categories.

Recommended next action

Review the working-tree diff, commit the adapter, quality-check, CI, and tutor-observability changes as one focused commit, push the branch, and confirm the GitHub quality workflow is green. Only then begin the remaining browser and hosted-Supabase verification work.

Final security and verification update

This appendix records the final local changes completed after the main roadmap report was prepared.

Browser security hardening

All five entry pages now declare a strict-origin referrer policy and a Content Security Policy. The policy blocks objects, limits scripts and styles to the project, jsDelivr, and Google Fonts, and limits network connections to the local origin and Supabase. It remains compatible with the current inline-script architecture.

Quality enforcement

The web-quality verifier now requires the referrer policy and CSP, in addition to page metadata, local asset existence, pinned Supabase client version, and adapter-only game platform calls.

Final verification

Repository verification passed. Web-quality verification passed. JavaScript syntax checks passed for js, PhysicsSim, and RoboMaze. The automated suite passed 32 of 32 tests with zero failures. The supplied Supabase screenshot confirms the legacy direct submit procedures are not executable by authenticated clients while the idempotent wrappers remain executable.

User action remaining

Review the working-tree diff, commit the focused changes, push the branch, and confirm GitHub Actions is green. Hosted browser and Supabase verification remain release checks that must be performed by the project owner.